

Windows - LDAP User Kerberoastable | rootme Writeup

written by : Alexander Sapo

Windows - LDAP User Kerberoastable

20 Points 

Kerberoast

Author

Podalirius, 17 November 2022

Level ?



Validations

3177 Challengers 1%

Note ?

★★★★★ 130 Votes

Statement

During your investigations, you found a backup of the company's KDAP made with `ldap2json`. Use the information in this dump to find the Kerberoastable user.

The flag is the email address of the Kerberoastable user.

What is an SPN?

A **Service Principal Name (SPN)** is a unique identifier for a service running under a specific account in Active Directory. It allows Kerberos to associate a service with the account that runs it.

In this case, we found:

```
servicePrincipalName: HTTP/SRV-RDS.rootme.local
sAMAccountName: a.newton
```

This means that the `a.newton` account is associated with the HTTP service hosted at `SRV-RDS.rootme.local`.

What is LDAP?

LDAP (Lightweight Directory Access Protocol) is a protocol used to access and query directory services such as Active Directory. Active Directory stores information about users, computers, groups, and other objects as directory records that can be queried through LDAP.

The LDAP data was converted into JSON using `ldap2json`, allowing us to analyze the records more easily with Python.

What is a Kerberoasting attack?

Kerberoasting is an attack technique in which an attacker requests a Kerberos service ticket for an account associated with an SPN. The ticket can then potentially be taken offline and cracked to recover the account's password.

Therefore, we searched the LDAP dump for accounts containing the `servicePrincipalName` attribute. We found:

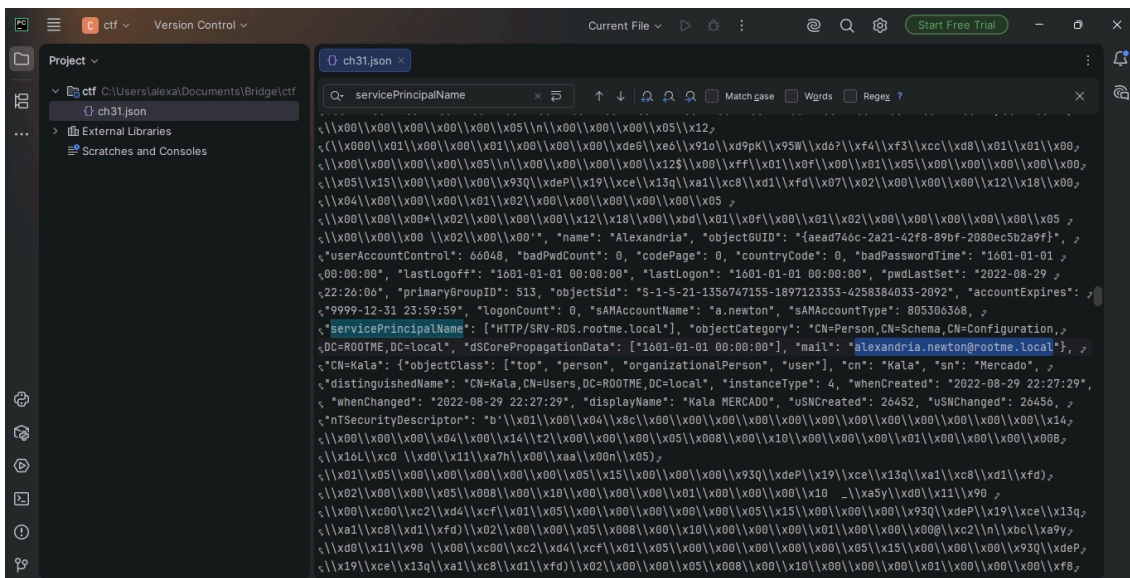
```
servicePrincipalName: HTTP/SRV-RDS.rootme.local
sAMAccountName: a.newton
mail: alexandria.newton@rootme.local
```

The account associated with the SPN was `a.newton`. We then examined the attributes of that same Active Directory user object and found the associated email address:

`alexandria.newton@rootme.local`.

The reason this email address is used is that it belongs to the **same LDAP/Active Directory record** as the account containing the SPN. The email field is simply another attribute of that user object.

quick search:



flag: `alexandria.newton@rootme.local`

reference:

<https://beta.hackndo.com/kerberoasting/>

<https://beta.hackndo.com/service-principal-name-spn/>

<https://beta.hackndo.com/kerberos/>

<https://www.youtube.com/watch?v=ct1ovt0hEAW>

<https://github.com/p0dalirius/ldap2json>

what is SPN?

what is LDAP?

what is Kerberoasting attack?